2026 스마트 의료 안전 컨퍼런스

SaMD 제조업체의 사이버보안 관리체계 구축·운영 어프로치 분석

제품의 보안성과 조직의 운영체계를 동시에 달성하기 위한 전략적 접근법

강의 초반부 — 구조적 분석

01 들어가며

왜 지금 이 논의인가

- **2025.01** 디지털의료제품법 시행
- **2025.04** 식약처 「디지털의료기기 전자적 침해행위 보안지침」 고시
- 심사 업무지침서 · 민원인 가이드라인 연이어 발행

사이버보안은 더 이상 품질활동의 하위 항목이 아니라
허가·변경관리·사후관리와 직접 연결된 규제 대응 영역이 되었습니다.

제조업체의 선택지

> "제품의 보안성"과 "조직의 운영체계"가 동시에 요구되며,
> 심사 제출자료와 실제 운영이 일치해야 한다.

"보안 기능을 넣느냐"가 아니라

"어떤 어프로치로 관리체계를 도입하고 운영할 것인가"

분석 프레임 — 두 축, 세 옵션

구분	도입(BUILD) 단계	운영(OPERATE) 단계
옵션 1	자체 수립	자체 운영
옵션 2	외부 전문가 조력 수립	외부 전문가 운영 대행
옵션 3	AI 활용	AI 적용

옵션 1·2는 **"주체"**의 문제, 옵션 3(AI)은 **"수단"**의 문제
→ AI는 단독 어프로치가 아닌 1과 2를 **가속·보강하는 레이어**

도입 ① 자체 수립

내부 인력이 정책·절차·양식·운영기준을 직접 설계·정착

강점

- 제품 아키텍처·SDLC에 최적화 설계
- 장기적 내재화, 외부 의존도 최소화
- 초기 컨설팅 비용 절감

약점

- 규제 해석 오류 리스크 (IEC 62304 등)
- 수립 기간 장기화 (6~12개월)
- "문서는 있으나 운영 안 되는" 형식화 위험

적합 조건

RA/QA·SW개발 리더 내부 보유, 제품 수 적음, 장기 내재화 지향 조직

도입 ② 외부 전문가 조력 수립

컨설팅사 도움으로 단기 구축, 운영 주체는 내부 유지

강점

- 법령·고시·심사 기대수준 즉시 반영
- 3자 관점 Gap 분석으로 사각지대 해소
- 수립 기간 단축 (3~6개월)

약점

- 초기 비용 발생
- 외부 산출물과 내부 현실 괴리 가능
- 내부 온보딩 약하면 운영 전환 실패

성공 조건: "문서 대신 써주는" 구조 × → 내부 실무자 워크숍 기반 공동 설계

도입 ③ AI 활용

수립을 대체하지 않고 가속한다

효과적 활용 영역

- 법령·고시 기반 Gap 분석 자동화
- 정책서·절차서·체크리스트 초안 생성 **(60~80% 단축)**
- STRIDE/TARA 위협 시나리오 초안 도출
- 심사 제출자료 간 정합성 점검

한계와 통제

- 규제 해석 최종 판단 → **사람 책임**
- 민감 설계정보 입력 통제 필요
- AI 산출물도 **검토·승인 절차 필수**

운영 ① 자체 운영

취약점 모니터링, 변경 검토, 사고 대응, 문서 유지관리를 내부 수행

강점

- 제품·고객·배포환경 깊은 이해
- 개발·QA·CS와 자연스러운 연계
- 역량의 조직 내 축적

약점

- 24/7 모니터링 체계 유지 어려움
- 고급 보안 분석 인력 채용·유지 고정비
- 일상업무에 밀려 정기점검 형식화

운영 ② 외부 전문가 운영 대행

강점

- 24/7 SOC, 최신 위협 인텔리전스
- 내부 인력 부족 완화
- 객관적 점검으로 사각지대 해소

약점

- 지속적 구독·위탁 비용
- 제품·임상 맥락 이해 부족 시 오탐 증가
- **법적 책임은 제조업자에게 귀속**

현실적 모델: 완전 대행보다 **부분 대행형** — 월간 취약점 모니터링, 분기 정기점검, 반기 문서 갱신 리뷰

운영 ③ AI 적용

운영 단계는 AI의 효과가 가장 크게 나타나는 영역

- **SBOM + CVE 자동 매칭** — 컴포넌트·신규 CVE 자동 대조, CVSS 기반 우선순위 알림
- **AI 이상 탐지** — 접근 로그·API 호출 패턴 정상 베이스라인 학습, 편차 탐지
- **사고 대응 어시스턴트** — 플레이북 가이드, 식약처 신고 양식 초안
- **정기 보고서 자동화** — 취약점·패치·사고 이력 집계, 보고서 초안
- **변경영향분석 보조** — 변경요청서↔위험평가서 영향항목 자동 추출

⚠ AI는 "보조" — 최종 판단(배포 중단, 사고 판정, 대외 통지)은 반드시 사람이 수행 (Human-in-the-Loop)

도입 단계 비교 요약

기준	자체 수립	외부 조력 수립	AI 활용
초기 속도	느림	빠름	**매우 빠름**
규제 해석 정확도	내부 역량 의존	**높음**	검토 없으면 불안정
내재화 수준	**높음**	중~높음	낮음~중
문서 품질 일관성	편차 큼	비교적 높음	**매우 높음**
단독 권장도	제한적	**가장 권장**	보조수단

운영 단계 비교 요약

기준	자체 운영	외부 운영 대행	AI 적용
제품 이해도	매우 높음	중간	낮음
지속 가능성	인력 확보 시 높음	계약 의존	운영체계 의존
전문분석 깊이	편차 큼	높음	보조적
비용 구조	인건비 중심	용역비 중심	도구·통제비
단독 권장도	필수 기반	부분 대행 권장	강한 보조수단

어느 하나만으로는 부족하다

1. **자체만으로는 느리고 위험하다** — 규제 해석 편차, 수립 기간, 전문성 공백
2. **외부만으로는 내재화가 안 된다** — 문서는 완성되나 운영은 공회전
3. **AI만으로는 책임을 질 수 없다** — 가속기일 뿐, 판단과 승인은 사람의 몫

"하나를 선택하는" 문제가 아니라
"어떻게 조합할 것인가"의 문제

최적 조합 제안

도입 단계

외부 전문가 조력 + AI 가속 + 내부 책임 승인

운영 단계

자체 운영 중심 + 외부 부분 대행 + AI 자동화

최적해는 기업 규모, 보안 성숙도, 규제 대응 시급성에 따라 달라집니다.
이어지는 중반부에서는 컨설팅사들의 대응 방식을 분석합니다.